第14章 轻量级密码和后量子密码

0. 学习目标总览

教材给出本章八个学习目标：

1. 解释嵌入式系统的概念。
2. 解释资源受限设备的概念。
3. 给出轻量级密码的概念及常见轻量级密码算法的类型。
4. 讨论影响轻量级密码算法设计的限制因素。
5. 讨论轻量级密码算法的安全要求。
6. 概述用于认证加密、哈希函数、消息认证码的轻量级密码。
7. 解释后量子密码算法的需求及受到影响的算法。
8. 概述设计后量子密码算法的数学方法。

本章讨论两个面向未来但解决不同问题的方向：轻量级密码力求降低安全算法对时间、存储、芯片面积和功耗的需求；后量子密码则为量子计算机可能破坏现有公钥密码的问题寻找新的数学基础。

```
第14章
  |
  |-- 轻量级密码
  |     |-- 对象：嵌入式系统、资源受限设备
  |     |-- 约束：面积、能耗、存储、通信、时间
  |     |-- 算法：AEAD、分组/流密码、哈希、MAC
  |     `-- 核心：安全性、成本、性能的折中
  |
  `-- 后量子密码
        |-- 威胁：Shor 与 Grover 算法
        |-- 影响：公钥算法、协议和产品
        `-- 路线：格、编码、多变量多项式、哈希签名
```

1. 学习目标 1：嵌入式系统

1.1 定义与特点

嵌入式系统 是产品中承担一个或一组专用功能的电路或软件系统，与笔记本、台式机等通用计算机相对应。广义地说，只要设备包含计算机芯片但不是通用工作站、台式机或笔记本，就可以视为嵌入式系统。

常见设备包括手机、数码相机、家用电器、家庭安全系统、打印机、汽车控制系统，以及自动化系统中的传感器和执行器。嵌入式系统通常具有以下特征：

- 为特定任务设计，而不是运行任意通用程序。
- 计算、存储、功耗和接口能力通常低于通用计算机。
- 大量部署于工业控制、汽车、医疗和物联网环境。
- 许多设备持续联网，因此同样需要认证、完整性和保密性保护。

1.2 微控制器

微控制器是在一个芯片中集成处理器、ROM 或闪存、RAM、时钟和 I/O 控制单元的系统，也称“芯片上的计算机”。它的处理器部分占用半导体面积较小，能效较高，适合作为低成本的专用处理器。

微控制器的处理器架构通常从 4 位到 32 位，运行频率多在 MHz 范围内，明显低于通用微处理器的 GHz 范围。它一般没有完整的人机接口，而是嵌入设备并在需要时执行预先确定的任务。

1.3 深度嵌入式系统

深度嵌入式系统是资源约束尤其明显的嵌入式系统。其程序逻辑通常烧入 ROM，之后不能重新编程，也没有用户接口。它们检测环境信息、进行基本处理并产生结果，常带有无线通信能力，并以传感器网络等形式大规模部署。

物联网在很大程度上依赖深度嵌入式系统。这类设备在内存、处理器能力、执行时间和功耗方面受到极端限制，是轻量级密码的主要应用对象。

2. 学习目标 2：资源受限设备

资源受限设备是易失性和非易失性存储器容量有限、处理器能力有限且数据传输率较低的设备。典型设备只配备 8 位或 16 位微控制器，RAM 和代码空间很小，并使用低功耗、低数据率的无线网络。

RFC 7228 将这类设备分为三类：

类别	RAM	闪存或 ROM	主要特征
0 类	远小于 10 kB	远小于 100 kB	资源极端受限，传统方式难以保护和管理，通常只预配置少量数据。
1 类	约 10 kB	约 100 kB	无法轻松运行完整协议栈，但可使用面向受限节点的协议直接参与通信。
2 类	约 50 kB	约 250 kB	基本可支持通用协议栈，但仍需轻量级、节能协议和较低传输带宽。

技术进步使嵌入式设备更便宜、更小和更省电，却不意味着它们拥有与通用计算机相当的资源。物联网设备往往还要求低成本和大规模部署，密码机制能够占用的资源比例仍然很小。

3. 学习目标 3：轻量级密码的概念与类型

3.1 基本概念

轻量级密码研究如何为资源受限设备设计密码算法。“轻量级”表示尽量减少算法对系统资源的需求，而不是忽略安全性。研究工作包括：

1. 对已有密码算法进行高效、紧凑的实现。
2. 设计适合受限环境的新型轻量级算法。

传统标准通常在安全性、性能和成本之间按通用平台条件折中，未必适合极小型传感器、RFID 标签和微控制器。

3.2 常见算法类型

轻量级密码研究主要集中于：

- 带有关联数据的认证加密（AEAD）。
- 轻量级分组密码和流密码。
- 轻量级密码学哈希函数。
- 轻量级消息认证码（MAC）。

教材指出，当时对轻量级非对称密码的关注较少。非对称算法通常只处理少量数据、调用频率较低，而且很多公钥算法的结构已经较为紧凑；一种可能用法是在数字签名中采用轻量级哈希函数。

新设计的轻量级算法常具有以下特征：

- 使用异或、循环移位、较小 S 盒和比特置换等简单运算。
- 分组和密钥长度相对较小。
- 密钥扩展简单，可动态生成子密钥。
- 轮函数简单，但迭代轮数较多。
- 与 AES、SHA-2 等算法相比，设计采用的安全边界较小。

4. 学习目标 4：轻量级密码的设计限制与折中

4.1 五类主要限制

ISO 29192-1 列出的主要限制如下：

限制	对算法设计的影响
芯片面积	安全电路可用面积有限，硬件实现通常用等价门电路（GE）衡量。
能耗	电池或环境供能有限，需要同时减少计算时间、工作频率、芯片面积和通信量。
代码与 RAM 空间	程序实现必须紧凑，运行时使用尽可能少的 RAM。
通信传输率	认证标记、密钥交换信息等安全开销必须尽量小。
执行时间	RFID、非接触卡等设备只能在有限通信时间内完成密码运算。

不同应用的安全重点并不相同。RFID 需要防止标签克隆、商品假冒、日志篡改和隐私泄露；家电需要认证控制命令和软件更新；农业、医疗传感器强调低功耗与数据真实性；工业控制和汽车通信还特别重视授权、可用性及隐私。

4.2 安全、成本与性能

轻量级密码的设计必须在三者间取得折中：

- 更长密钥和更多轮数通常提高安全性，但会降低吞吐率并增加功耗。
- 更复杂的实现可能提高安全性，却会占用更大芯片面积和存储空间。
- 串行架构成本较低、面积较小，但延迟较高；并行架构性能较高，但成本和面积增加。

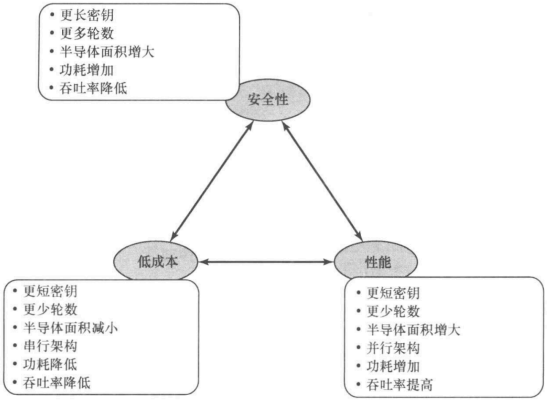


图 14.1　轻量级密码折中

图 14.1 轻量级密码在安全性、成本和性能之间的折中

对称密码可采用三种主要硬件架构：

架构	处理方式	主要特点
并行或展开	同一时钟周期并行执行多轮或多部分运算	吞吐率高，芯片面积大。
循环或未展开	每次完成一轮，再反馈完整状态处理下一轮	面积与速度居中。
串行	每次只更新状态的一部分，多次操作完成一轮	面积最小，执行时间最长。

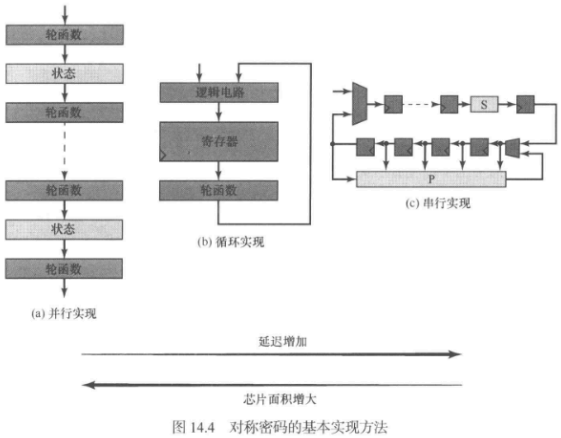


图 14.4　对称密码的基本实现方法

图 14.4 对称密码的三种基本实现方法

5. 学习目标 5：轻量级密码的安全要求

5.1 安全强度与操作限制

ISO 29192 将轻量级密码的最低安全强度规定为 80 位，即攻击所需工作量约为 2^{80} 次运算；大多数标准建议至少达到 128 位。NIST 轻量级密码初步配置文件则要求传统计算机上的密码分析攻击至少需要 2^{112} 次运算。

较低安全强度只适合威胁能力受限且单密钥处理数据量很少的应用。系统设计者必须明确单个密钥的安全操作上限，并在达到上限前更换密钥。

对于分组长度为 n 位的分组密码，当处理分组数为 q 时，许多工作模式的安全性会在

$$\frac{q^2}{2^n}$$

达到显著水平时开始降低。例如，$n = 64$ 时，单个密钥处理约 2^{32} 个分组后，碰撞相关威胁开始变得重要。因此，较短分组虽然有利于紧凑实现，却限制了同一密钥能够安全保护的数据量。

5.2 侧信道攻击

侧信道攻击利用密码设备物理实现产生的信息泄露恢复密钥。可利用的信息包括：

- 运行时间；
- 功耗；
- 电磁辐射；
- 声音辐射。

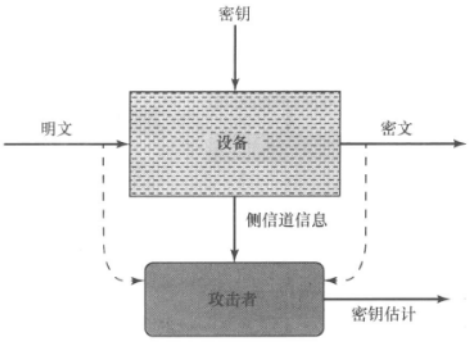


图 14.3　侧信道攻击的基本操作过程

图 14.3 侧信道攻击的基本操作过程

资源受限设备常部署在物理上不安全的环境中，攻击者容易长期观察设备，并结合已知明文或密文分析侧信道差异。教材给出的典型 AES 攻击可逐字节猜测密钥，测试量约为 16×2^8，远低于对 128 位密钥的穷举。

防御目标是消除或减弱密钥位与侧信道信息之间的相关性。教材列出的措施包括：添加随机延迟、插入空指令使不同密码计算花费相同时间，以及增加硬件逻辑使功耗表现随机化。

6. 学习目标 6：轻量级密码算法

6.1 认证加密与 SEA

分组密码是加密工作模式和部分认证模式的基本单元；流密码同样适用于受限环境，第 8 章介绍的 Grain-128 就是一个例子。

可伸缩加密算法 SEA 是轻量级分组密码的代表。它采用 Feistel 结构，分组长度和密钥长度均为 n，字长为 b，并要求 n 是 $6b$ 的倍数。基本运算只有异或、S 盒、字间和字内循环移位以及模 2^b 加。

设第 i 轮左右分支为 L_i, R_i，子密钥为 K_i。加密轮为

$$L_{i+1} = R_i$$

$$R_{i+1} = R(L_i) \oplus r\left(S(R_i \boxplus K_i)\right)$$

解密使用同一轮函数结构，只把第一项改为 $R^{-1}(L_i)$。子密钥扩展也复用 S 盒、移位、模加和异或等简单运算。

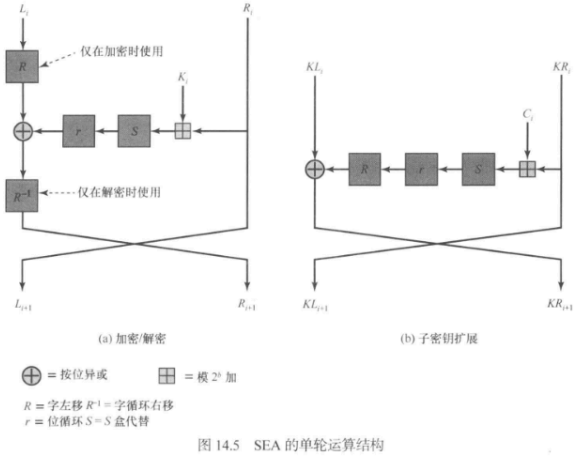


图 14.5 SEA 的单轮运算结构

图 14.5 SEA 的单轮运算结构

SEA 只需实现少量基本运算，可灵活调整分组、密钥和字长，并在紧凑实现与性能间取得平衡。

6.2 轻量级哈希函数 Photon

轻量级哈希函数与传统哈希函数的差异主要是：

1. 在不要求抗碰撞性的应用中，可以采用更小的内部状态和输出长度。
2. 目标协议处理的消息通常很短，因此可专门针对短消息优化。

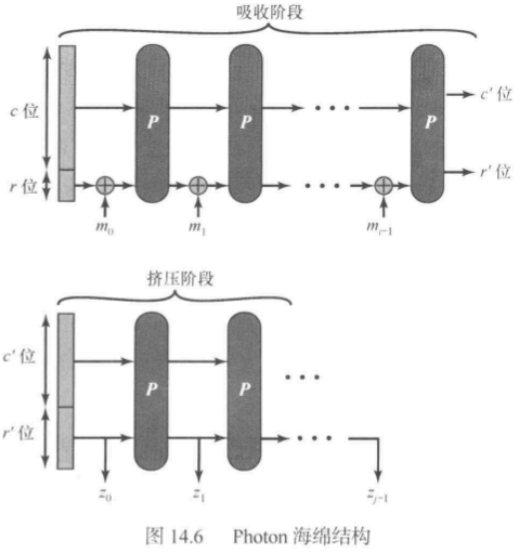


图 14.6 Photon 海绵结构

图 14.6 Photon 海绵结构

Photon 使用类似 SHA-3 的海绵结构。内部状态长度为

$$t = c + r$$

其中 r 为每次吸收的位数，c 为容量，教材给出的 Photon 结构中哈希输出长度 $n = c$。算法包括：

- **吸收阶段**：消息填充后分成 r 位分组，各分组与状态的速率部分异或，再对整个状态执行置换 P。
- **挤压阶段**：从状态中输出若干分组，分组间继续执行置换，最后截断为 n 位。

Photon 的五个版本输出长度从 80 位到 256 位，内部状态仅为 100 位到 288 位。置换采用适合硬件实现的类 AES 结构，每轮包括 AddConstants、SubCells、ShiftRows 和 MixColumnsSerial，共执行 12 轮。

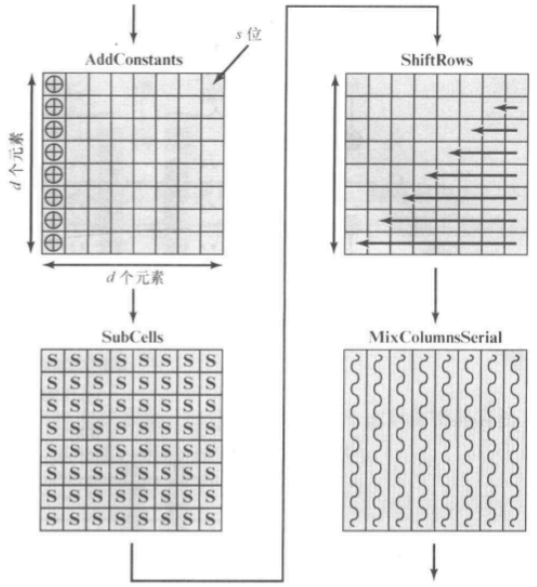


图 14.7　Photon 置换的一轮

图 14.7 Photon 置换的一轮

6.3 轻量级 MAC 与 SipHash

设计轻量级 MAC 有两条路径：

1. 将现有 MAC 构造与轻量级原语结合，例如用轻量级分组密码实现 CMAC，或用轻量级哈希函数实现 HMAC。
2. 直接设计新的轻量级 MAC。

SipHash 是教材介绍的专用轻量级 MAC，主要针对短消息优化，目标是安全、高效和简单。它具有以下结构：

- 使用 128 位密钥，分为两个 64 位字 k_0, k_1。
- 内部状态由四个 64 位字 v_0, v_1, v_2, v_3 组成。
- 输出为 64 位认证标记。
- 不需要密钥扩展。
- 只使用加法、异或和循环左移等简单操作。

SipHash-c-d 中，c 表示吸收相邻消息分组之间执行的 SipRound 轮数，d 表示收尾阶段的轮数。消息分组逐个异或进状态并执行 c 轮，处理完全部消息后再执行 d 轮，最终输出

$$T = v_0 \oplus v_1 \oplus v_2 \oplus v_3$$

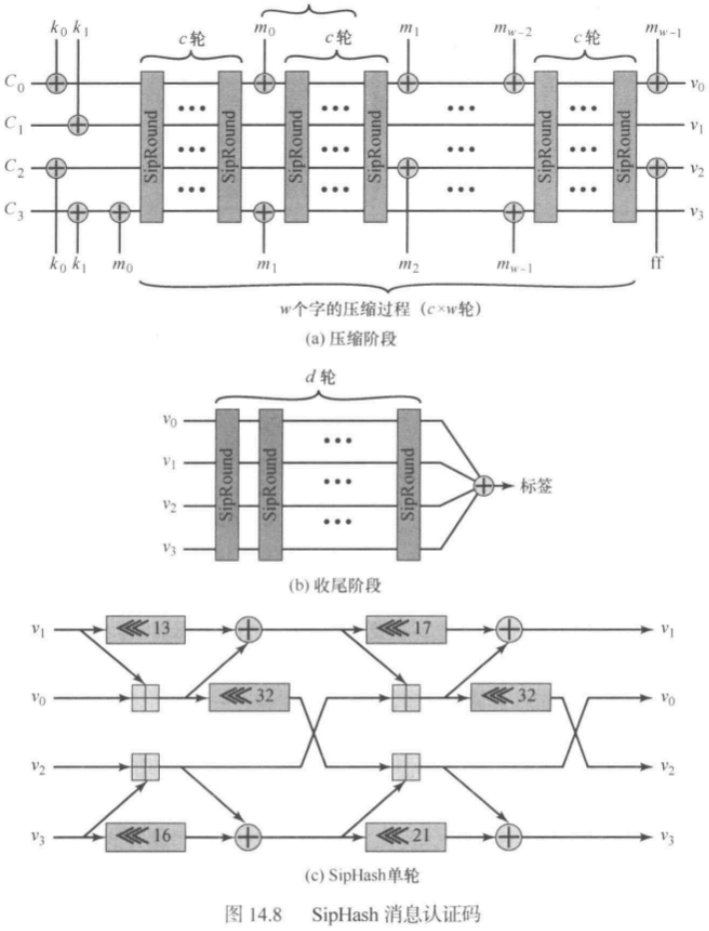


图 14.8　SipHash 消息认证码

图 14.8 SipHash 消息认证码

教材指出，SipHash-2-4 是推荐的快速选择；SipHash-4-8 以大约一半速度换取更保守的安全性。

7. 学习目标 7：后量子密码的需求与影响

7.1 量子计算的威胁

后量子密码研究能够抵抗潜在量子计算机攻击的密码算法。与轻量级密码主要关注对称密码和哈希函数的效率不同，后量子密码主要关注非对称密码的安全性。

量子位具有两个重要性质：

- **叠加**：测量前可处于多个状态的叠加。
- **纠缠**：多个量子位形成不能由各自状态简单组合表示的整体状态。

量子位数量增加时，系统状态空间呈指数增长；对一组量子位的运算可同时作用于叠加状态。但构造实用通用量子计算机仍面临量子位脆弱、环境要求苛刻及软硬件体系不成熟等困难。

7.2 Shor 与 Grover 算法

Shor 算法能够在量子计算机上以多项式时间求解整数因子分解和离散对数问题。因此，依赖这些问题的 RSA、Diffie-Hellman、DSA、ECDH 和 ECDSA 等公钥算法都将失去安全基础。单纯增加 RSA 或 ECC 密钥长度不是可持续方案，因为量子攻击开销只随密钥长度近似线性增加，而传统计算机上的正常运算成本增长更快。

Grover 算法能以 $O(\sqrt{N})$ 时间搜索无序空间，而经典搜索需要 $O(N)$。对 n 位对称密钥，理论安全强度降为约 $n/2$ 位；对哈希函数也会降低相应搜索强度。与 Shor 算法不同，这类影响通常可通过把对称密钥或哈希输出长度加倍来补偿，例如使用 256 位密钥维持约 128 位安全强度。

算法类型	量子计算影响
AES 等对称密码	需要更长密钥。
SHA-2、SHA-3 等哈希函数	需要更长输出。
RSA	不再安全。
DSA、Diffie-Hellman	不再安全。
ECDSA、ECDH	不再安全。

7.3 密码生命期与迁移

密码生命期是特定密钥被授权用于指定目的的时间范围。它包括：

- **发起方使用期限（OUP）**：使用密钥加密新数据的时间段。
- **接收方使用期限（RUP）**：密文仍需保留并可能被解密的时间段。

RUP 的结束时间可能远晚于 OUP，因此即使某密钥已停止加密新数据，仍需在较长时间内保留解密能力。长期保密数据可能在量子计算机出现后被解密，所以后量子迁移必须在量子计算机实用化之前完成。

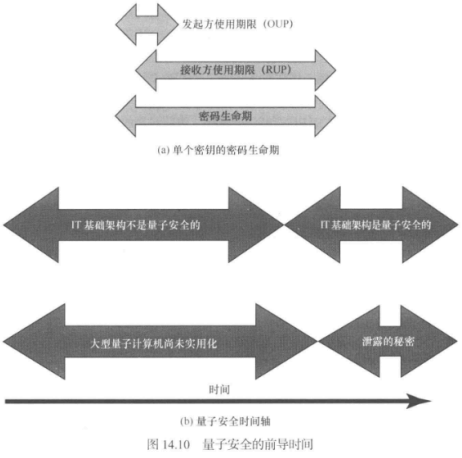


图 14.10　量子安全的前导时间

图 14.10 密码生命期与量子安全迁移的前导时间

量子威胁会沿三个层次扩散：

```
易受攻击的公钥密码系统
  -> 使用这些算法的安全协议
  -> 基于这些协议构建的产品和信息系统
```

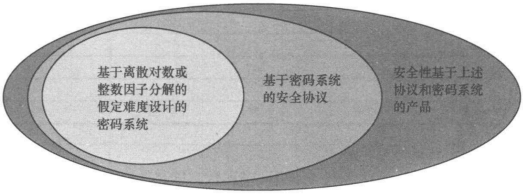


图 14.11　易受量子计算攻击的实体

图 14.11 易受量子计算攻击的实体

因此，后量子迁移不是单纯替换一个算法，还涉及密钥管理过程、协议和产品实现的整体更新。

8. 学习目标 8：后量子密码的数学方法

教材归纳了四类主要路线：

方法	基础困难问题	一般特点
格密码	高维格中的最近向量、最短向量等问题	相对简单、高效且易于并行。
编码密码	隐藏结构纠错码的译码问题	速度较快，但密钥很长。
多变量多项式密码	有限域上多变量二次方程组求解	数字签名方案通常需要很长密钥。
哈希签名	密码学哈希函数的安全性	结构高效，但常需记录签名状态且签名数量有限。

NIST 不打算只采用一种方法，因为公钥加密、签名和密钥建立的需求复杂，各方案的数学基础、实现属性和优缺点差异很大。

8.1 格密码

秩为 n 的 m 维格由一组线性无关基向量 $b_1, \ldots, b_n$ 的整数线性组合构成：

$$L = \left\{ \sum_{i=1}^{n} x_i b_i \mid x_i \in \mathbb{Z},\ b_i \in \mathbb{R}^m \right\}$$

同一个格可以由多组不同的基表示，有些基由短、近似正交的向量组成，计算较容易；另一些基向量较长，处理困难。这种“同一格、不同基”的差异可以用于构造公钥和私钥。

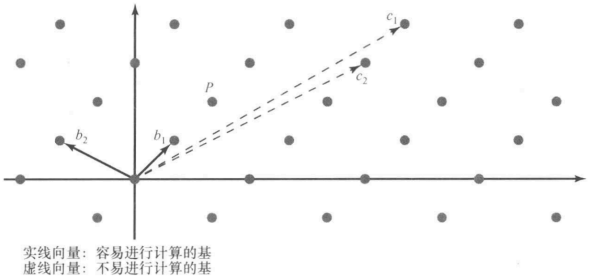


图 14.12　二维格的两个基

图 14.12 同一个二维格的两组基

格密码依赖的典型困难问题包括：

- **最近向量问题（CVP）**：给定格和空间向量，寻找距离它最近的格向量。
- **最短向量问题（SVP）**：寻找格中最短的非零向量。

NTRU 系列使用具有额外对称性的格。私钥对应由短向量组成、易于计算的格基；公钥是同一格的另一组长基。解密者利用私钥基完成最近格点计算，而由公钥基恢复私钥基在计算上不可行。

8.2 编码密码

一个 (n, k) 纠错码把 k 位消息向量 m 映射为 n 位码字：

$$c = mG$$

其中 G 是 $k \times n$ 生成矩阵。对应校验矩阵 H 满足

$$GH^{\mathrm{T}} = \mathbf{0}$$

收到码字 c' 后，可通过 $c'H^{\mathrm{T}}$ 判断是否检测到错误，并依据纠错码性质纠正一定数量的错误。

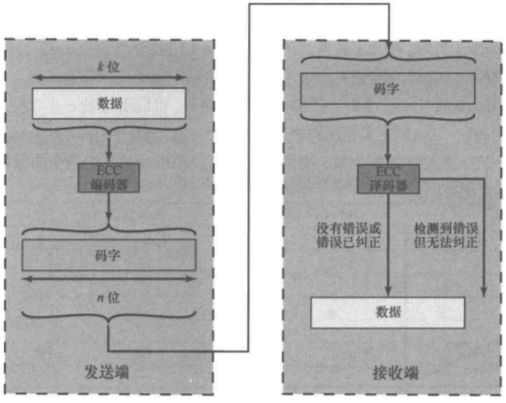


图 14.13　(n, k)纠错编码

图 14.13 (n, k) 纠错编码

McEliece 方案使用 Goppa 码。私钥包括 Goppa 码生成矩阵 G、置换矩阵 P 和可逆矩阵 S，公钥为

$$G' = SGP$$

发送方对消息 x 计算

$$x' = xG' + e$$

其中 e 是具有规定错误数的随机误差向量。接收方利用私钥变换和秘密译码算法消除误差并恢复消息；攻击者只掌握置乱后的公开编码结构，传统计算机或量子计算机都难以逆向求解。

8.3 多变量多项式密码

多变量方案基于有限域上多变量二次方程组求解困难。公钥是一组多项式映射

$$P(x_1, \dots, x_n) = \big(p_1(x_1, \dots, x_n), \dots, p_m(x_1, \dots, x_n)\big)$$

每个 p_i 包含二次项、一次项和常数项。加密时直接计算公开映射 $P(m)$；私钥是易于求值的逆映射 P^{-1}。安全性依赖于从公开的多项式组求解其逆或求解方程组的困难性。

数字签名使用相反方向：签名者利用私钥逆映射为消息哈希 $H(m)$ 求出签名向量 s，验证者检查

$$P(s) \stackrel{?}{=} H(m)$$

为隐藏一个容易求逆的二次映射 F，可用两个可逆映射 S, T 构造公开复合映射

$$P = S \circ F \circ T$$

私钥由 S, F, T 组成。

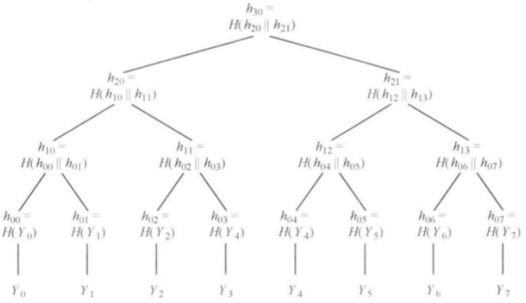
8.4 哈希签名

Lamport 一次性签名设哈希输出为 b 位。私钥包含 $2b$ 个秘密串 $S_{0,k}, S_{1,k}$，公钥包含这些秘密串各自的哈希值。签名消息 m 时：

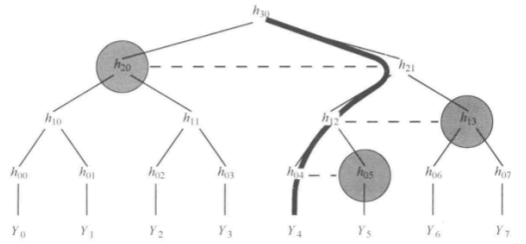
1. 计算 $H(m)$。
2. 若第 k 位为 0，公开 $S_{0,k}$；若为 1，公开 $S_{1,k}$。
3. 验证者对公开的秘密串求哈希，并与公钥中由 $H(m)$ 各位选出的值比较。

一次签名会公开私钥的一半，因此同一密钥对只能安全使用一次；此外，公钥、私钥和签名都较长。

Merkle 哈希树把多个 Lamport 公钥组织成树。叶节点是一次性公钥的哈希值，父节点为两个子节点连接后的哈希值，最终树根作为长期公钥。若树有 $N = 2^n$ 个叶节点，则最多可认证 N 个一次性签名。



(a) 带有8个叶节点的Merkle树



(b) Merkle树的认证路径

图 14.14　Merkle 哈希树的例子

图 14.14 Merkle 哈希树及认证路径

消息 m_i 的完整签名包括 Lamport 签名、对应一次性公钥 Y_i，以及从该叶节点到根所需的各层兄弟节点：

$$S_i = (\mathrm{LS}_i, Y_i, h_{0,x}, h_{1,x}, \ldots, h_{n-1,x})$$

验证者先用认证路径重算 Merkle 根，确认 Y_i 属于该树，再使用 Y_i 验证 Lamport 签名。该方法使长期公钥缩短为一个哈希值，并允许多个签名，但签名者必须准确记录哪些一次性密钥已经使用；状态记录错误会破坏安全性。

本章关键术语整理

术语	核心含义
嵌入式系统	为产品中的专用功能设计的计算系统。
深度嵌入式系统	无用户接口、难以重新编程且资源极端受限的专用设备。
资源受限设备	存储、处理器能力和通信速率受到明显限制的设备。
轻量级密码	尽量降低安全算法资源需求的密码学研究方向。
等价门电路（GE）	衡量密码硬件实现芯片面积的单位。
侧信道攻击	利用时间、功耗、电磁或声音等物理泄露恢复秘密的攻击。
SEA	可伸缩的轻量级 Feistel 分组密码。
Photon	使用小型海绵结构的轻量级哈希函数。
SipHash	针对短消息优化、输出 64 位标签的轻量级 MAC。
后量子密码	设计用于抵抗量子计算攻击的密码算法。
Shor 算法	量子环境下高效求解因子分解和离散对数的算法。

术语	核心含义
Grover 算法	将无序搜索复杂度从 $O(N)$ 降至 $O(\sqrt{N})$ 的量子算法。
密码生命期	密钥从开始用于保护数据到不再需要相关密码操作的完整时间范围。
OUP / RUP	发起方使用期限与接收方使用期限。
CVP / SVP	格中的最近向量问题与最短向量问题。
McEliece	基于隐藏结构纠错码的公钥密码方案。
多变量多项式密码	基于有限域多变量二次方程组求解困难的公钥方案。
Lamport 签名	每个密钥对只能使用一次的哈希签名方案。
Merkle 哈希树签名	用哈希树根统一认证多个一次性签名公钥的方案。

学习目标自检

1. 能否解释嵌入式系统、微控制器和深度嵌入式系统之间的关系？
2. 能否比较 RFC 7228 中 0 类、1 类和 2 类资源受限设备的资源与通信能力？
3. 能否说明轻量级密码的定义、主要算法类型及典型设计特征？
4. 能否列出轻量级密码设计的五类限制，并解释安全性、成本和性能之间的折中？
5. 能否说明短分组为何限制单密钥数据量，以及资源受限设备为何特别容易受到侧信道攻击？
6. 能否概括 SEA、Photon 和 SipHash 的基本结构及其适合受限设备的原因？
7. 能否比较 Shor 和 Grover 算法对公钥密码、对称密码与哈希函数的不同影响，并解释迁移为何受密码生命期约束？
8. 能否分别说明格、编码、多变量多项式和哈希签名方案依赖的困难问题及主要优缺点？